COMPTIA SECURITY+ SY0-701 DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · Physical Attacks

Mestre CyberSec · **Aula 2.4 — Physical Attacks** (4:04) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Ataque físico: brute force física (cortar cadeado, força porta); RFID cloning (clonar badge NFC); environmental (pular cerca, furar parede). Defesa: mantrap/vestibular control, badge + PIN (2 fatores físico), câmeras, alarmes, monitorar log RFID com alarme de horário incomum.

💡 Highlights que a prova CompTIA cobra

- RFID cloning com um device de $500 copia um badge (proximity)
- Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'clones an access badge' = RFID cloning

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — Physical Attacks)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Força Bruta Física (N/A)

Ataque físico que usa força direta para contornar ou quebrar um controle, como cortar cadeado, forçar porta ou destruir barreira.

⚠️ ***Armadilha CompTIA:*** *Se a questão descreve danos ou força contra fechadura, porta ou cerca, pense em brute force físico, não em hacking lógico.*

• Clonagem de RFID

Cópia dos dados de um crachá ou cartão de proximidade RFID para outro dispositivo, permitindo usar a credencial clonada para acesso físico.

⚠️ ***Armadilha CompTIA:*** *'Clones an access badge' = RFID cloning. Badge de proximidade sem criptografia é vulnerável; defesa inclui badge com PIN e monitoramento de logs.*

• Ataque Ambiental (N/A)

Ataque físico que contorna controles de perímetro por falhas ambientais, como pular cerca, escalar muros ou cortar/perfurar parede.

⚠️ ***Armadilha CompTIA:*** *Cerca, muro, parede, telhado ou vegetação explorados indicam environmental attack; não confunda com controle de acesso lógico.*

• Mantrap (Vestíbulo de Controle de Acesso) (N/A)

Portal de entrada pequeno com duas portas intertravadas que permite passagem de apenas uma pessoa ou grupo por vez, prevenindo tailgating e piggybacking.

⚠️ ***Armadilha CompTIA:*** *Questões sobre impedir entrada não autorizada junto com funcionário autorizado pedem mantrap/access control vestibule.*

• Crachá + PIN (Autenticação de Dois Fatores Física) (2FA)

Controle de acesso físico que exige algo que você possui, como crachá ou token, e algo que você sabe, como um PIN, fornecendo autenticação de dois fatores para entrada.

⚠️ ***Armadilha CompTIA:*** *Se a defesa combina badge com PIN, é 2FA físico; só badge é fator único e pode ser clonado ou roubado.*

• CCTV (Circuito Fechado de Televisão)

Vigilância por vídeo usada para monitorar, dissuadir e registrar atividades físicas para investigação de incidentes e aplicação de controle de acesso.

⚠️ ***Armadilha CompTIA:*** *Câmeras são detecção, dissuasão e evidência; não impedem fisicamente a entrada sozinhas.*

• Sistemas de Alarme (N/A)

Sensores e mecanismos de alerta que detectam eventos de segurança física, como violação de porta, movimento ou entrada não autorizada, e notificam respondedores.

⚠️ ***Armadilha CompTIA:*** *Alarmes detectam e notificam; para prevenir tailgating, combine com mantrap, câmeras e resposta.*

• Monitoramento de Log de Acesso RFID

Revisão de logs de acesso RFID e alerta sobre anomalias, como horários incomuns ou tentativas negadas repetidas, para detectar credenciais clonadas ou mal utilizadas.

⚠️ ***Armadilha CompTIA:*** *Log de RFID com horário incomum é gatilho para detectar clonagem de crachá; defesa é alerta e monitoramento, não apenas crachá físico.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Tailgating vs. Piggybacking

🏠 **Analogia Intuitiva:** Tailgating (carona sorrateira) é quando você passa seu cartão na catraca do metrô e uma pessoa desconhecida cola nas suas costas e passa junto sem você autorizar ou perceber. Piggybacking (carona com consentimento ingênuo) é você estar segurando a porta de vidro do prédio corporativo para um rapaz simpático vestido com uniforme de entregador segurando caixas pesadas de pizza porque você quis ser 'educado'. No tailgating a vítima não autorizou; no piggybacking a cortesia social da vítima foi explorada.

🔍 **Causa Raiz / Por que foi criado:** A empatia e a cortesia humana levam as pessoas a segurar portas para desconhecidos, contornando travas físicas. A falta de barreiras mecânicas que forcem a passagem estritamente individual permite que credenciais válidas autentiquem múltiplos indivíduos.

🛡️ **Visão do Auditor de GRC:** Instalar catracas de controle de acesso ópticas com sensores de proximidade que acionam alarme sonoro caso duas pessoas passem com um único cartão (anti-tailgating sensors); conduzir treinamentos contínuos de conscientização estabelecendo a regra obrigatória de 'nunca segurar a porta para ninguém'; e exigir uso ostensivo de crachá de identificação.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'unauthorized individual closely follows an authorized employee through a secure door without their knowledge' -> Tailgating. Trigger: 'authorized worker willingly holds the door for an individual with hands full' -> Piggybacking. Mitigação arquitetônica: Mantrap / Access Control Vestibule.

📌 Mantrap (Access Control Vestibule) e Gaiola de Faraday (Faraday Cage)

🏠 **Analogia Intuitiva:** O Mantrap (vestíbulo de eclusa) é como a câmara de descompressão de uma nave espacial ou as portas duplas de uma agência bancária de valores: você abre a Porta 1 e entra em uma pequena antecâmara fechada. A Porta 1 se tranca e você fica retido. Somente após a Porta 1 estar firmemente travada e seu crachá/biometria ser aprovado (muitas vezes com balança no chão para garantir que há apenas uma pessoa), a Porta 2 se abre para o cofre. A Gaiola de Faraday é como uma caixa forrada com malha metálica densa que bloqueia qualquer sinal de rádio: colocar um celular apreendido lá dentro é como jogá-lo em um buraco negro sem sinal, impedindo que um cúmplice envie um comando remoto para apagar as fotos do aparelho.

🔍 **Causa Raiz / Por que foi criado:** Portas físicas convencionais não conseguem impedir a entrada física de mais de uma pessoa por abertura. No âmbito de radiofrequência, ondas eletromagnéticas atravessam paredes normais de gesso e alvenaria, exigindo blindagem condutiva para isolamento de sinais de celular, Wi-Fi e Bluetooth.

🛡️ **Visão do Auditor de GRC:** Exigir intertravamento eletrônico obrigatório em mantraps que impedem a abertura simultânea das duas portas em datacenters (requisito PCI-DSS e SOC 2); e homologar bolsas ou salas de Faraday nos laboratórios de resposta a incidentes e custódia forense digital.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'physical security control designed with an interlocking two-door vestibule where Door B cannot open until Door A closes' -> Mantrap / Access Control Vestibule. Trigger: 'prevents wireless signals, cellular signals, or remote wipe commands from reaching a seized device' -> Faraday Cage / Faraday Bag.

📌 Clonagem de RFID / Proximity Cards e USB Drop Attack

🏠 **Analogia Intuitiva:** Clonar um cartão RFID legado é como alguém passar bem perto de você no elevador com uma máquina copiadora portátil no bolso e tirar um xerox perfeito da chave física da sua casa através da sua calça, sem você sentir nada. O invasor depois vai até sua casa e abre a porta com a chave copiada. O USB Drop Attack é como o criminoso jogar carteiras recheadas de notas falsas e bombons envenenados no estacionamento da empresa: ele sabe que algum funcionário curioso vai achar o pendrive 'perdido', levar para o escritório e plugar no notebook de trabalho para ver o que tem dentro.

🔍 **Causa Raiz / Por que foi criado:** Crachás RFID de baixa frequência (125 kHz Proximity Cards) transmitem seu código fixo em texto claro sem nenhuma autenticação criptográfica mútua. No USB drop, atacantes utilizam dispositivos HID (Human Interface Device / BadUSB) que se passam por teclados normais e digitam comandos maliciosos em milissegundos assim que são conectados.

🛡️ **Visão do Auditor de GRC:** Migrar o parque de credenciais para cartões inteligentes de alta frequência com criptografia ponta a ponta (como MIFARE DESFire EV3 ou Seos); implementar autenticação física multifator (Crachá + PIN numérico ou Biometria na porta); e desabilitar o uso de armazenamento USB removível através de GPO/EDR.

> ⚠️ **Como cai na Prova CompTIA:** Trigger: 'attacker uses a handheld scanning tool within close proximity of a user to replicate building access' -> RFID Cloning. Trigger: 'malicious flash drives intentionally scattered in an office lobby or parking area' -> USB Drop Attack.

📌 Shoulder Surfing e Dumpster Diving

🏠 **Analogia Intuitiva:** Shoulder surfing é o curioso atrás de você na fila do caixa eletrônico ou no assento do avião esticando o pescoço por cima do seu ombro para ver a senha que você digita ou o contrato aberto na tela do seu laptop. Dumpster diving (vasculhar o lixo) é o golpista ir de madrugada até a caçamba de lixo na calçada da empresa, rasgar os sacos pretos e revirar papéis em busca de rascunhos com senhas anotadas em post-its, extratos de pagamentos ou manuais de rede descartados inteiros.

🔍 **Causa Raiz / Por que foi criado:** Falta de higiene física, telas visíveis para pessoas não autorizadas e processos negligentes de descarte de resíduos que não trituram documentos impressos ou não destroem mídias físicas antes do descarte.

🛡️ **Visão do Auditor de GRC:** Fornecer filtros de privacidade físicos (Privacy Filters/Screens) para notebooks de colaboradores móveis; adotar Política de Mesa Limpa (Clean Desk Policy); instituir lixeiras de descarte seguro trancadas a chave; e contratar serviço de trituração transversal (cross-cut shredding) ou incineração certificado conforme NIST SP 800-88.

> ⚠️ **Como cai na Prova CompTIA:** Trigger: 'attacker peers over a user's shoulder to view login credentials on a laptop' -> Shoulder Surfing (Mitigação: Privacy Screen). Trigger: 'attacker rummages through company trash to find sensitive network topologies or passwords' -> Dumpster Diving (Mitigação: Cross-cut shredding).

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Pessoa não autorizada aproveita a abertura da porta para passar colada logo atrás de um colaborador sem o consentimento dele	**Tailgating**
Colaborador autorizado segura gentilmente a porta de segurança para uma pessoa que alega estar carregando caixas pesadas	**Piggybacking**
Sistema físico de controle de acesso composto por duas portas intertravadas onde uma só abre quando a outra fecha	**Mantrap (Access Control Vestibule)**
Dispositivo ou sala blindada com malha condutiva que impede a passagem de sinais sem fio e comandos de apagamento remoto	**Gaiola de Faraday (Faraday Cage / Faraday Bag)**
Atacante utiliza leitor portátil próximo ao bolso da vítima para copiar o código estático do crachá de proximidade	**Clonagem de RFID (RFID Cloning)**
Película colocada sobre o monitor do notebook que escurece a tela para quem tenta olhar pelos lados	**Filtro de Privacidade (Privacy Screen / Privacy Filter)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um atacante fica perto da entrada de funcionários com um leitor NFC oculto e captura o identificador único dos crachás RFID dos funcionários enquanto passam. Atualmente, os crachás sozinhos destrancam a porta do saguão. Qual controle impede mais diretamente que um identificador de crachá capturado seja usado depois para entrar no prédio?

A) Adicionar mais câmeras de CFTV cobrindo a entrada

B) Exigir que os funcionários apresentem o crachá e digitem um PIN na porta

C) Aumentar o alcance de leitura do leitor RFID para reduzir falhas de leitura

D) Pedir aos funcionários que mantenham os crachás em carteiras ao caminhar

QUESTÃO 2 · CENÁRIO DE EXAME

Um ladrão usou corta-cadeados para cortar o cadeado da porta de um armário de rede e roubou um switch. O armário contém infraestrutura crítica e fica em um corredor de pouco movimento. Qual mitigação aborda melhor o ataque de força bruta física?

A) Substituir o cadeado por uma fechadura reforçada e conjunto de porta reforçada

B) Instalar uma luz acionada por movimento no corredor

C) Exigir que visitantes se registrem na recepção

D) Ativar segurança de porta no switch de rede

QUESTÃO 3 · CENÁRIO DE EXAME

O perímetro de um depósito usa uma cerca de tela com arame farpado. Atacantes jogam um cobertor sobre o arame farpado, escalam a cerca e entram no pátio à noite. Qual melhoria mitiga melhor esse ataque ambiental?

A) Melhorar a cerca com topo anti-escalada e manter uma zona livre ao seu redor

B) Instalar um leitor de crachá na doca de carregamento do depósito

C) Exigir um PIN para todas as entradas de funcionários

D) Aumentar a retenção de gravações de CFTV de 7 para 30 dias

QUESTÃO 4 · CENÁRIO DE EXAME

Funcionários de um data center passam o crachá na entrada principal, mas pessoas não autorizadas frequentemente entram logo atrás pela mesma porta. Qual controle físico é projetado para impor a entrada de uma pessoa por vez?

A) Vestíbulo de controle de acesso com portas intertravadas

B) Crachá de visitante com cor diferente

C) Câmera de CFTV apontada para a entrada

D) Porta de saída de emergência com barra antipânico

QUESTÃO 5 · CENÁRIO DE EXAME

O crachá RFID de um funcionário é roubado em uma cafeteria. O crachá sozinho abre todas as portas do escritório, incluindo a sala de servidores. Qual mudança impede mais diretamente que um crachá roubado conceda acesso à sala de servidores?

A) Exigir tanto o crachá quanto um PIN para entrada na sala de servidores

B) Instalar uma câmera de segurança dentro da sala de servidores

C) Mover o leitor de crachá da sala de servidores para o outro lado da porta

D) Ativar o registro de todos os eventos de acesso por crachá

QUESTÃO 6 · CENÁRIO DE EXAME

Um analista de segurança revisa os registros de acesso RFID e vê um crachá de funcionário usado no laboratório de pesquisa às 3:17 da manhã. O funcionário está de férias e normalmente trabalha das 9:00 às 17:00. Qual controle detetivo identificaria melhor esse evento suspeito quase em tempo real?

A) Configurar o monitoramento de registros de acesso RFID para alertar sobre horários incomuns de acesso

B) Reemitir todos os crachás de funcionários a cada 90 dias

C) Substituir a porta do laboratório por uma porta de núcleo sólido

D) Adicionar uma catraca na entrada principal do saguão

QUESTÃO 7 · CENÁRIO DE EXAME

Invasores fora do horário arrombaram uma doca de carregamento três vezes, mas a empresa não tem evidência em vídeo porque a área não é gravada. Qual controle apoia melhor tanto a dissuasão quanto a investigação pós-incidente?

A) Instalar câmeras de CFTV cobrindo a doca de carregamento com gravações retidas

B) Exigir crachá mais PIN na entrada principal do escritório

C) Implantar um man-trap na entrada do data center

D) Monitorar registros RFID para acessos incomuns no elevador

QUESTÃO 8 · CENÁRIO DE EXAME

Um assaltante corta a linha telefônica de um pequeno escritório antes de forçar a porta dos fundos. O sistema de alarme não consegue enviar notificações porque seu único caminho de comunicação é a linha telefônica cortada. Qual melhoria aborda melhor essa fraqueza?

A) Adicionar backup celular e detecção de violação ao sistema de alarme

B) Adicionar mais sensores de movimento dentro do escritório

C) Substituir a maçaneta da porta dos fundos por uma trava tetra

D) Começar a reter gravações de CFTV por 90 dias

QUESTÃO 9 · CENÁRIO DE EXAME

Um escritório compartilhado tem um rack de servidores protegido apenas por uma fechadura padrão de gabinete. Um atacante forçou a fechadura com uma chave de fenda e roubou um disco. Qual mitigação aborda melhor esse ataque de força bruta física?

A) Substituir o rack por um gabinete reforçado e fechadura de alta segurança

B) Criptografar os dados em todos os discos dos servidores

C) Ativar o registro de acesso por crachá para a porta do escritório

D) Instalar uma película de privacidade na janela do escritório

QUESTÃO 10 · CENÁRIO DE EXAME

Um atacante entra em um prédio quebrando o drywall de uma sala de servidores que compartilha uma parede com um corredor público. A porta da sala de servidores tem controles de acesso fortes, mas a parede é de drywall comum. Qual mitigação aborda melhor esse ataque ambiental?

A) Reforçar a parede com tela de aço ou concreto e adicionar sensores de vibração

B) Exigir crachá mais PIN na porta da sala de servidores

C) Instalar uma câmera de CFTV no corredor público

D) Monitorar registros RFID para passagem de crachá fora do horário comercial

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Exigir que os funcionários apresentem o crachá e digitem um PIN na porta

Exigir crachá mais PIN cria autenticação física de dois fatores: o crachá é algo que você tem, e o PIN é algo que você sabe. Um crachá clonado sozinho deixa de ser suficiente para destrancar a porta. CFTV, maior alcance de leitura e esconder crachás não impedem o uso de um crachá clonado para acesso.

Questão 2: Alternativa A — Substituir o cadeado por uma fechadura reforçada e conjunto de porta reforçada

O ataque foi força bruta física contra a fechadura e a porta. Substituir o cadeado por uma fechadura reforçada e reforçar a porta aumenta a resistência a corte, alavancagem e entrada forçada. Iluminação pode dissuadir, mas não impede o corte. Registro de visitantes e segurança de porta não protegem a porta do armário.

Questão 3: Alternativa A — Melhorar a cerca com topo anti-escalada e manter uma zona livre ao seu redor

Escalar a cerca é um ataque ambiental ao perímetro. Cercas anti-escalada, como topos curvos ou espigões giratórios, combinadas com zona livre e detecção perimetral, tornam a escalada e a aproximação muito mais difíceis. Leitores de crachá, PINs e maior retenção de CFTV não impedem diretamente a escalada da cerca.

Questão 4: Alternativa A — Vestíbulo de controle de acesso com portas intertravadas

Um vestíbulo de controle de acesso, também chamado de man-trap, usa portas intertravadas para permitir que apenas uma pessoa passe por vez. Ele mitiga diretamente o tailgating. Crachá de visitante, CFTV e saída de emergência não impedem, por si sós, que alguém siga uma pessoa autorizada por uma porta.

Questão 5: Alternativa A — Exigir tanto o crachá quanto um PIN para entrada na sala de servidores

Crachá mais PIN é autenticação física de dois fatores. Um crachá roubado sozinho não basta porque o atacante também precisa do PIN. CFTV pode registrar a intrusão, mover o leitor é segurança por obscuridade, e o registro ajuda na detecção, mas não impede a entrada.

Questão 6: Alternativa A — Configurar o monitoramento de registros de acesso RFID para alertar sobre horários incomuns de acesso

Monitorar registros de acesso RFID e alertar sobre horários ou padrões incomuns pode detectar rapidamente crachás clonados, roubados ou usados indevidamente. Reemitir crachás, melhorar portas e instalar catracas no saguão são úteis, mas não fornecem detecção em tempo real de um uso anômalo de crachá.

Questão 7: Alternativa A — Instalar câmeras de CFTV cobrindo a doca de carregamento com gravações retidas

CFTV fornece dissuasão e cria evidência gravada para investigar intrusões físicas. Crachá mais PIN, man-traps e monitoramento de registros RFID protegem ou detectam acesso em pontos controlados, mas não gravam atividade na doca de carregamento.

Questão 8: Alternativa A — Adicionar backup celular e detecção de violação ao sistema de alarme

O backup celular dá ao alarme um caminho alternativo para reportar uma intrusão quando a linha telefônica é cortada. A detecção de violação pode alertar quando a fiação ou o painel do alarme é adulterado. Mais sensores, uma trava tetra e retenção de CFTV ajudam, mas não resolvem a perda de comunicação do alarme.

Questão 9: Alternativa A — Substituir o rack por um gabinete reforçado e fechadura de alta segurança

O ataque teve como alvo a fechadura e o gabinete físicos. Um gabinete reforçado com fechadura de alta segurança resiste a alavancagem e entrada forçada. A criptografia de disco protege os dados se um disco for roubado, mas não impede o roubo físico. Registro e películas de privacidade não protegem o rack.

Questão 10: Alternativa A — Reforçar a parede com tela de aço ou concreto e adicionar sensores de vibração

O ataque contornou a porta penetrando na parede. Reforçar a parede com tela de aço, concreto ou outros materiais endurecidos torna a perfuração ou quebra muito mais difícil, e sensores de vibração podem detectar tentativas. Controles de porta, CFTV no corredor e monitoramento RFID não endurecem diretamente a parede.